

이론 8장

# 데이터 관리·보안과 동향

고객의 개인정보를 맡은 회사의 책임

한국기술교육대학교 경영학부

경영데이터베이스및실습 (CCT770) · 2026학년도 2학기

# 이 장을 마치면

|      |                                   |
|------|-----------------------------------|
| 목표 ① | 기업이 데이터를 보유하는 것이 왜 책임의 문제인지 설명    |
| 목표 ② | 최소 권한 원칙에 따라 계정별 접근 권한과 뷰를 설계     |
| 목표 ③ | 백업의 종류와 복구의 기본 개념, 운영 원칙 설명       |
| 목표 ④ | 개인정보 보호의 일반 원칙을 다운유통 사례에 적용       |
| 목표 ⑤ | 클라우드 DB·빅데이터·AI가 DB 실무를 바꾸는 방식 개관 |

경영 DB 이론 편람 8장 · 지키고, 살리고, 미래를 읽는다

# 오늘 다루는 여덟 가지

---

**1** 데이터를 가진다는 것은 책임을 진다는 것

**2** 접근 제어 — 아무나 다 보게 하지 않는다

**3** 뷰 — 보여줄 것만 보여주는 창

**4** 백업과 복구 — 잃을 수 있다는 전제로

**5** 개인정보 보호의 기본 원칙

**6** 클라우드 데이터베이스 — 서버실 없이

**7** 빅데이터와 NoSQL — 표에 담기지 않는 데이터

**8** AI와 데이터베이스 — 좋은 데이터가 먼저다

# 고객 데이터는 고객이 회사를 믿고 맡긴 것

## ① 유출

01

고객 이메일 명단이 새어  
스팸과 피싱에 쓰인다

## ② 소실

02

디스크 고장으로 주문 기록이  
사라진다

## ③ 오남용

03

권한 없는 직원의 열람  
개인 식별 정보의 통째 복사

한가람 고객이 이메일을 알려 준 것은 주문 확인과 배송 안내를 위해서 — 새어 나가거나 엉뚱한 광고에 쓰여도 된다는 허락이 아니다

# 세 사고의 예방책 = 이 장의 세 기둥

## 접근 제어

01

불 사람만 보게 한다  
(유출·오남용 예방) — 권한과 뷰

## 백업·복구

02

잃어도 되살릴 수 있게  
(소실 대비) — 백업 전략과 복구 절차

## 개인정보 보호

03

필요한 만큼만 모으고 목적대로만  
수집·이용·파기의 원칙

1장에서 「데이터는 자산」이라 배웠다면, 마지막 장에서는 그 자산에 따라오는 책임을 배운다

## 2. 접근 제어

# 최소 권한 — 업무에 필요한 최소한만

```
1  -- 마케팅팀: 고객·주문을 '읽기'만 - 고치거나 지울 일은 없다
2  GRANT SELECT ON daon.customers TO 'marketing'@'%';
3  GRANT SELECT ON daon.orders    TO 'marketing'@'%';
4
5  -- 영업팀: 주문은 접수·수정까지, 고객은 읽기만
6  GRANT SELECT, INSERT, UPDATE ON daon.orders TO 'sales'@'%';
7  GRANT SELECT ON daon.customers TO 'sales'@'%';
8
9  -- 부서 이동으로 더 이상 필요 없어지면 회수
10 REVOKE SELECT ON daon.customers FROM 'marketing'@'%';
```

4장에서 분류만 배웠던 DCL — 권한은 「누가(계정) × 무엇에(테이블·뷰) × 무슨 일을」 단위로 쪼개서 준다

2. 접근 제어

# 다운유통 계정별 권한 설계

| 계정(역할)    | customers        | products | orders·order_items | employees       |
|-----------|------------------|----------|--------------------|-----------------|
| 영업팀       | 읽기               | 읽기       | 읽기·입력·수정           | 접근 불가           |
| 마케팅팀      | 읽기 (개인정보는 뷰로 제한) | 읽기       | 읽기                 | 접근 불가           |
| 물류팀       | 접근 불가            | 읽기·재고 수정 | 읽기·상태 수정           | 접근 불가           |
| 경영지원팀(인사) | 접근 불가            | 접근 불가    | 접근 불가              | 읽기·입력·수정        |
| DBA(관리자)  | 전체               | 전체       | 전체                 | 전체 — 소수 인원으로 한정 |

처음부터 좁게 시작해 필요할 때 넓힌다 — 넓게 주는 것은 쉽고 좁히는 것은 어렵다

# 권한 운영의 네 가지 원칙

01

## 개인 계정

공용 계정은  
「누가 했는가」를 모른다

02

## 역할 단위 관리

「영업팀 역할」에 권한을  
묶고 사람을 역할에

03

## 즉시 회수

퇴사·이동 시 바로  
남은 권한이 보안 구멍

04

## 민감 열은 더 좁게

employees.salary는  
인사 담당과 경영진만

같은 테이블 안에서도 열 단위 통제가 필요하다 — 그 도구가 다음 절의 뷰

### 3. 뷰

## 뷰 — 보여줄 것만 보여주는 창

```
1  -- 분석에는 등급·도시·포인트면 충분하다. 이메일은 뺀다.
2  CREATE VIEW v_customer_stats AS
3  SELECT cust_id, grade, city, joined_date, points
4  FROM    customers;
5
6  -- 마케팅 계정에는 원본 대신 뷰만 열어 준다
7  GRANT SELECT ON daon.v_customer_stats TO 'marketing'@'%';
8
9  -- 영업팀에게는 '취소 아닌 주문'만 보이는 창을 낼 수도 있다
10 CREATE VIEW v_valid_orders AS
11 SELECT order_id, cust_id, emp_id, order_date, status
12 FROM    orders
13 WHERE   status <> '취소';
```

뷰 = 질의 결과에 이름을 붙여 테이블처럼 쓰는 가상 테이블 — 조회할 때마다 원본에서 정의된 질의가 실행된다

### 3. 뷰

# 테이블 권한으로는 못 하는 것을 뷰가 한다

01

## 열 숨김

이메일·연봉을 빼면  
그 열의 존재조차 못 다룬다

02

## 행 제한

WHERE를 심어 자기 부서·  
자기 담당 데이터만

03

## 질의 단순화

복잡한 조인·집계를  
SELECT \* FROM 뷰 한 줄로

04

## 원본 변경의 완충

테이블이 바뀌어도  
뷰 정의만 고치면 된다

실무 표준 조합 — 원본 테이블은 잠그고, 뷰에만 SELECT 권한을 준다(권한 = 누가, 뷰 = 무엇이)

### 3. 뷰

# 뷰는 만능이 아니다

#### ■ 틀리기 쉬운 것

! 뷰만 잘 만들면 원본 권한은 열어 뒀도 된다

! 뷰로도 INSERT/UPDATE를 자유롭게 할 수 있다

! 뷰는 데이터를 복사해 둔 별도 테이블이다

#### ■ 바로잡는 법

✓ 원본 테이블 권한을 함께 열어 두면 우회로가 남는다 — 원본은 잠근다

✓ 집계·조인이 얹힌 뷰는 INSERT/UPDATE가 안 되는 읽기 전용이 보통이다

✓ 데이터가 복사되지 않는다 — 조회할 때마다 원본에서 질의가 실행된다

4. 백업과 복구

# 「사고는 난다」는 전제로 사본을 만든다

| 방식    | 무엇을 복사하나          | 장점                  | 단점                   |
|-------|-------------------|---------------------|----------------------|
| 전체 백업 | 데이터베이스 전부         | 복구가 단순하다 (하나만 풀면 됨) | 시간·저장 공간을 많이 쓴다      |
| 차등 백업 | 마지막 전체 백업 이후 바뀐 것 | 복구 시 전체+차등 2개면 된다   | 전체 백업에서 멀어질수록 커진다    |
| 증분 백업 | 직전 백업 이후 바뀐 것만    | 매회 가장 작고 빠르다        | 복구 시 전체+증분 여러 개를 차례로 |

디스크는 고장 나고, 사람은 실수하고(WHERE 없는 DELETE!), 화재·정전 같은 재해도 온다 — 백업은 사업 연속성의 문제

## 백업 운영의 네 가지 원칙

01

### 정기·자동

사람이 기억하는 백업은  
잊힌다 — 일정에 따라 자동

02

### 다른 곳에 보관

같은 건물이면 화재 한 번에  
둘 다 잃는다

03

### 보존 기간 설계

어제 것만 남기면 지난주  
실수는 못 살린다

04

### 백업 자체도 보호

고객 개인정보가 통째로  
— 접근 통제·암호화

예: 주 1회 전체 + 매일 증분 · 며칠·몇 주 단위의 세대를 남긴다

#### 4. 백업과 복구

# 백업은 사진, 로그는 그 이후의 동영상

## 시점 복구

01

마지막 백업 복원 + 로그 재생  
→ 사고 직전 시점까지

## 복구 목표 시점

02

「얼마까지  
잃어도 되는가」

## 복구 목표 시간

03

「얼마 만에  
되살려야 하는가」

복구해 본 적 없는 백업은 백업이 아니다 — 주기적으로 복구 리허설까지 해야 백업이 완성된다

# 제도의 세부는 달라도 뼈대는 같다

|           |                                           |
|-----------|-------------------------------------------|
| 최소 수집     | 목적에 필요한 최소한만 — 배송에 생년월일이 필요 없다면 받지 않는다    |
| 목적 내 이용   | 밝힌 목적 그대로만 — 주문 확인용 이메일을 동의 없이 광고에 쓰지 않는다 |
| 동의와 투명성   | 무엇을 왜 모으는지 알리고 동의 — 마케팅 수신 동의는 별도         |
| 안전한 관리    | 접근 통제·암호화로 보호할 책임은 수집한 쪽에 있다              |
| 보유 기간과 파기 | 목적을 다한 정보는 지운다 — 「언젠가 쓸지 모르니」는 어긋난다       |
| 정보 주체의 권리 | 고객은 열람·정정·삭제를 요구할 수 있고, 회사는 절차를 갖춘다       |

개인정보 = 살아 있는 개인을 알아볼 수 있는 정보 — 결합해 식별되는 정보까지 포함해서 생각한다

# 원칙이 다운유통에서 보이는 모습

| 원칙        | 다운유통에서의 실무 모습                                                                   |
|-----------|---------------------------------------------------------------------------------|
| 최소 수집     | customers에 주민번호·생년월일 같은 열 자체가 없다 · email이 NULL 허용인 것도 「필수가 아닌 정보는 강제하지 않는다」는 설계 |
| 목적 내 이용   | 이메일은 주문·배송 안내용 · 쿠폰 발송(14주차 미주문 고객 캠페인)에 쓰려면 마케팅 수신 동의 여부를 먼저 확인                |
| 안전한 관리    | 마케팅 분석에는 이메일을 뺀 v_customer_stats 뷰만 제공(3절), 백업 파일도 암호화(4절)                      |
| 파기        | 탈퇴 고객 정보는 정해진 절차로 삭제·분리 보관 — 주문 통계가 깨지지 않게 식별 정보만 지우는 설계                        |
| 정보 주체의 권리 | 「내 정보 지워 주세요」요구를 처리할 절차와 담당을 미리 정해 둔다                                           |

일반 원칙만 다뤘다 — 실제 적용 요건(동의 방식·보유 기간·신고 절차 등)은 소관 기관의 최신 공식 안내를 확인하고 담당 부서와 협의

## 비식별 처리 — 마스킹의 개념

```
1  -- 이름은 첫 글자만, 이메일은 앞 두 글자만 남기고 가린다
2  SELECT CONCAT(LEFT(name, 1), '**')          AS 이름,
3             CONCAT(LEFT(email, 2), '****@****') AS 이메일,
4             grade, city, points
5  FROM    customers;
6  /*
7  한** | ga****@**** | VIP    | 서울 | 4500
8  오** | se****@**** | GOLD  | 부산 | 2300
9  ...
10 */
11 -- 실무에서는 이런 결과를 뷰로 만들어 분석 계정에 제공한다
```

「등급별 매출 기여도」를 구하는 데 고객 이름은 한 글자도 필요 없다 — 지우거나(익명처리) 가려서(마스킹) 넘긴다

# 자가발전기에서 전력회사 전기로

| 관점    | 자체 구축(온프레미스)            | 클라우드(관리형)                 |
|-------|-------------------------|---------------------------|
| 초기 비용 | 서버·서버실·전문 인력에 목돈        | 초기 투자 거의 없이 시작 — 월 비용     |
| 운영 부담 | 설치·패치·백업·장애 대응 전부 자체 처리 | 상당 부분을 사업자가 대행            |
| 확장    | 서버 증설에 구매·설치 기간 필요      | 몇 번의 설정으로 성능·용량 확장        |
| 통제    | 데이터 위치·환경을 완전히 통제       | 사업자 정책·서비스 범위 안에서 운영      |
| 비용 구조 | 고정비 중심 (안 써도 나간다)       | 변동비 중심 (쓴 만큼 — 방치하면 새는 돈) |

클라우드 DB = 사업자 데이터센터의 DBMS를 인터넷 너머에서 빌려 쓰고, 쓴 만큼 비용을 낸다

# 중소기업에 매력적이지만 숙제도 따라온다

## 비용 관리

01

쓴 만큼 내는 구조는  
방심하면 예산을 넘는다

## 데이터의 위치

02

고객 정보가 어느 나라 데이터센터에  
있는지가 규제상 중요할 수 있다

## 종속성

03

사업자 전용 기능에 깊이 의존하면  
갈아타기 어려워진다

빌려 써도 책임은 넘어가지 않는다 — 계정 권한 관리와 개인정보 보호 책임은 데이터를 맡은 회사의 것

# 빅데이터 — 흔히 3V로 요약한다

01

## 규모 (Volume)

기존 방식으로 담기 어려운 양  
클릭 로그는 주문 기록의 수백 배

02

## 다양성 (Variety)

표·텍스트·이미지·영상·로그가  
섞여 있다

03

## 속도 (Velocity)

실시간으로 생성되고  
실시간에 가까운 처리를 요구

상품 리뷰 텍스트, 상품 사진, 클릭 기록, 상담 채팅 — 1장에서 본 비정형 데이터가 양·종류·속도로 폭발한다

# 대체가 아니라 분업

| 구분      | 관계형 DB                    | NoSQL                           |
|---------|---------------------------|---------------------------------|
| 구조      | 스키마를 먼저 정하고 담는다 (3장)      | 유연한 구조 — 항목마다 생김새가 달라도 된다       |
| 강점      | 무결성·트랜잭션·강력한 SQL 질의       | 수평 확장·대량 처리·유연성                 |
| 질의      | SQL 표준                    | 제품마다 다른 방식 (일부는 SQL 유사 언어 제공)   |
| 어울리는 자리 | 주문·결제·재고·회계 — 틀리면 안 되는 기록 | 로그·리뷰·세션·추천 — 크고 빠르고 유연해야 하는 기록 |

NoSQL 대표 유형 — 키-값 저장소(초고속 조회·캐시) · 문서형(리뷰처럼 유연한 구조) · 그래프형(추천 관계망)

# AI는 데이터베이스를 먹고 사는 기술

01

## 수요 예측

판매 이력으로 다음 달  
주문량 → 발주(SCM)

02

## 고객 이탈 예측

주문 간격·금액 추세로  
떠날 조짐 → CRM 캠페인

03

## 추천

함께 팔리는 상품 패턴  
(장바구니 분석)

04

## 자연어 질의

AI가 SQL을 만들어 줘도  
검증하는 눈은 사람의 몫

모델의 품질 상한선을 데이터의 품질이 정한다 — AI 시대에 데이터베이스의 가치는 오히려 커진다

# 쓰레기를 넣으면 쓰레기가 나온다

01

## 무결성 (3장)

등급 표기가 제멋대로인  
데이터를 막는다

02

## 트랜잭션 (5장)

장부의 앞뒤가  
맞게 지킨다

03

## 정규화 (6장)

중복과 이상현상을  
없앤다

04

## 관리·보호 (8장)

지키고 살리는  
운영의 기본기

유행하는 기술은 바뀌어도 '믿을 수 있는 데이터를 만들고 지키는 능력'의 값은 떨어지지 않는다

# 확인 퀴즈

마케팅팀에 고객 분석용 데이터를 주되, 이메일은 보이지 않고 등급·도시·포인트는 쓰게 하려면 실무 표준 조합으로 가장 적절한 것은?

① 원본 권한을 주고 이메일은 보이지 말라고 안내

② 이메일 뺀 뷰에만 SELECT 권한, 원본 테이블 권한은 잠근다

③ 마케팅팀 공용 계정 하나를 팀원 모두가 함께 쓴다

④ customers의 이메일 열을 아예 삭제한다

## 정답 및 해설

### 정답

② 이메일을 뺀 뷰(v\_customer\_stats)에만 SELECT 권한, 원본은 잠근다

### 해설

권한은 누가 접근하는가를 정하고 뷰는 무엇이 보이는가를 정하므로, 원본은 잠그고 뷰에만 권한을 주는 조합이 실무 표준입니다. 안내에 기대는 방식은 통제가 아니고, 공용 계정은 누가 했는지 알 수 없게 만들며, 이메일 열 삭제는 주문·배송 안내라는 본래 목적까지 없애는 과잉 조치입니다.

# 핵심 요약

|      |                                        |
|------|----------------------------------------|
| 핵심 ① | 고객 데이터는 맡은 것 — 유출·소실·오남용을 막는 것이 책임     |
| 핵심 ② | 최소 권한 — GRANT/REVOKE로 줌게, 개인 계정과 즉시 회수 |
| 핵심 ③ | 뷰는 열 숨김·행 제한의 창 — 원본은 잠그고 뷰에만 권한       |
| 핵심 ④ | 백업은 전체·차등·증분 조합, 다른 곳에 보관, 복구 리허설까지    |
| 핵심 ⑤ | 개인정보는 최소 수집·목적 내 이용·안전 관리·기한 후 파기      |
| 핵심 ⑥ | 클라우드·NoSQL·AI 시대에도 토대는 무결성 있는 데이터      |

분석에는 마스킹 등 비식별 처리 — 신원은 필요 없는 경우가 대부분이다

# 경영 DB 이론 편람 여덟 장

1·2장

3·4장

5·6장

7·8장

1장 경영과 데이터  
2장 데이터베이스와 DBMS

핵심어

데이터·정보·지식, DBMS 3대 기능

3장 관계형 데이터 모델  
4장 SQL의 이론적 기초

핵심어

키·무결성, DDL·DML·DCL·TCL

5장 트랜잭션과 동시성  
6장 데이터베이스 설계 이론

핵심어

ACID·락, 함수적 종속·정규화

7장 기업 정보시스템과  
데이터베이스  
8장 데이터 관리·보안과 동향

핵심어

ERP·DW, 권한·백업·개인정보

무결성(3장)·트랜잭션(5장)·정규화(6장)·관리와 보호(8장) — 전부 AI 이전에 갖춰야 할 데이터의 기본기

이론 8장 마무리

## 학습 마무리

권한(GRANT/REVOKE)과 뷰를 SQL로 직접 만들어 봅니다

✓ 최소 권한과 계정 설계

✓ 백업·복구와 개인정보 원칙

✓ 뷰로 보여줄 것만 보여주기

✓ 클라우드·빅데이터·AI 동향

관련 주차

10주차 뷰·인덱스·권한(DCL)